Fase 1 — Arquitectura

Red, segmentación, flujo de logs, dimensionamiento y decisiones

Caso	C23 — TalentoRemoto Staffing TI S.A.S. (empresa ficticia, 10 empleados, 20 equipos)
Consultor(es)	Angel David Rey Duran
Programa / institución	Ingeniería de Sistemas — Unidades Tecnológicas de Santander
Versión / fecha	

1. Diagrama de red y de flujo de logs

TalentoRemoto Staffing TI S.A.S. no tiene oficina: los consultores se conectan desde redes domésticas a una VPN alojada en la nube. La arquitectura separa las redes domésticas (no confiables) del plano de servidores, del plano de seguridad (SIEM y consola EDR) y de la gestión. Direccionamiento privado de ejemplo; en el laboratorio se implementa con una red virtual aislada (host-only o NAT interna).

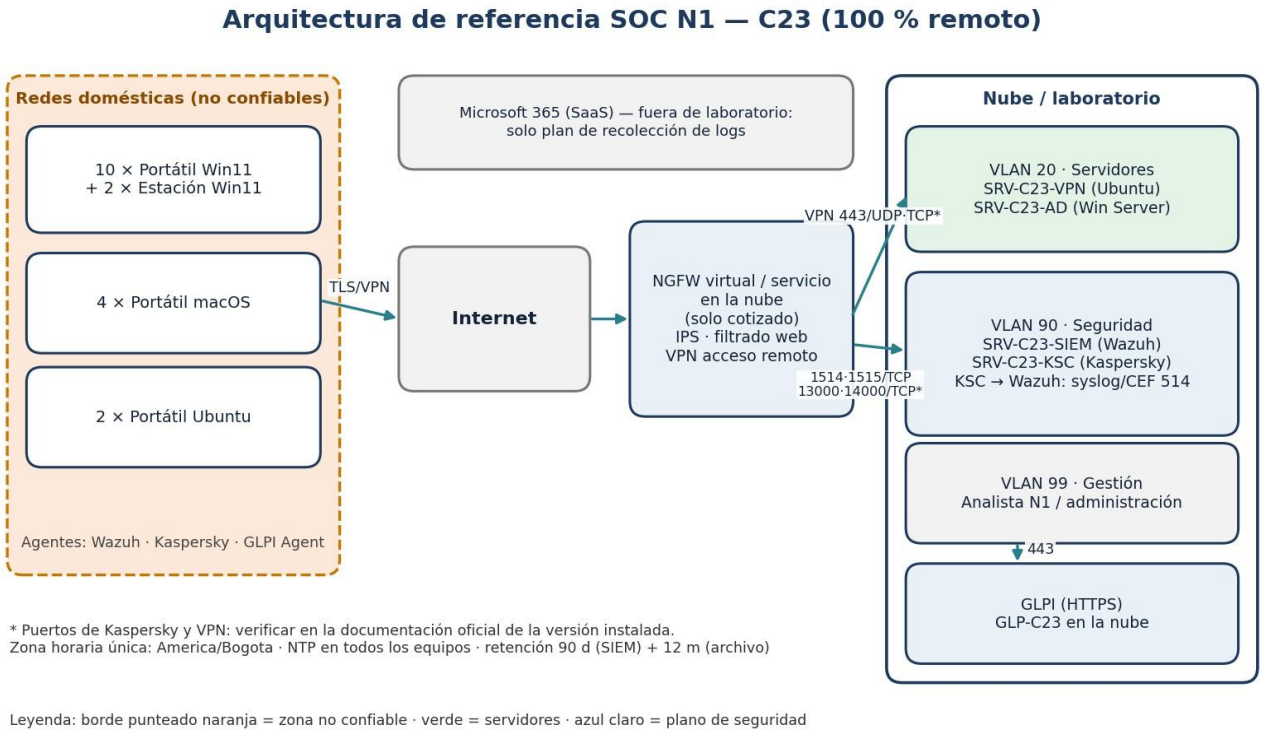


Figura 1. Arquitectura de referencia adaptada al caso C23. Entregar también el archivo editable (diagrams.net) y el PNG.

2. Segmentación y reglas mínimas

VLAN / segmento	Uso	Subred de ejemplo	Reglas mínimas (mínimo privilegio)
10 — Usuarios remotos (pool VPN)	18 equipos de usuario conectados por VPN	10.10.10.0/24	Salida a Internet filtrada por el NGFW; acceso a servidores solo por los puertos necesarios; sin acceso a VLAN 90 salvo agentes (1514/1515, 13000/14000).
VLAN / segmento	**Uso**	**Subred de ejemplo**	**Reglas mínimas (mínimo privilegio)**

20 — Servidores en la nube	SRV-C23-VPN, SRV-C23-AD	10.10.20.0/24	Administración solo desde VLAN 99; el servidor VPN es el único expuesto a Internet (puerto de la VPN).
30 — Invitados	No aplica (sin oficina)	—	No se crea; se documenta la decisión.
90 — Seguridad	SRV-C23-SIEM, SRV-C23-KSC	10.10.90.0/24	Recibe eventos de agentes y NGFW; acceso solo de analistas desde VLAN 99.
99 — Gestión	Analista N1, administración de NGFW y servidores	10.10.99.0/24	Acceso por VPN con MFA recomendado; origen autorizado de administración.

En un trabajo 100 % remoto la «VLAN 10» es en la práctica un **pool de direcciones VPN** y no una red física; las redes domésticas quedan fuera del control de la empresa y se tratan como zona no confiable. El agente se conecta por VPN siempre que sea posible; si la VPN cae, puede reportar por Internet con TLS hacia el manager restringiendo el origen por NGFW.

3. Tabla de flujo de logs y puertos

Origen	Destino	Puerto / protocolo	Propósito
Agentes Wazuh (Win, macOS, Ubuntu, servidores)	Wazuh manager	1514/TCP	Envío de eventos
Agentes Wazuh	Wazuh manager	1515/TCP	Registro de agentes (enrollment)
Analista N1	Wazuh Dashboard	443/TCP	Consola del SIEM
NGFW	Wazuh manager	514/UDP o TCP	Syslog del firewall (tráfico, IPS, VPN, cambios)
Kaspersky Security Center	Wazuh manager	514/UDP o TCP	Eventos en formato CEF
Network Agent (endpoints)	Kaspersky Security Center	13000/TCP (y 14000/TCP)	Gestión de agentes (verificar en la documentación)
Analista N1	Kaspersky Security Center	13291/TCP (consola) / 443 (consola web)	Administración (verificar)
Endpoints	GLPI en la nube	443/TCP	Inventario con GLPI Agent
Analista N1	GLPI en la nube	443/TCP	Gestión de tickets
GLPI	Servidor SMTP	587/TCP	Notificaciones por correo
Microsoft 365	Wazuh (módulo office365, plan)	443/TCP (API)	Logs de inicio de sesión y auditoría — solo plan, fuera del laboratorio

Los puertos de Wazuh son los de la instalación por defecto. Los de Kaspersky varían según la versión y la consola: verificar la tabla de puertos de la documentación oficial del producto elegido.

4. Dimensionamiento para 20 agentes

Con 20 agentes y un margen de crecimiento del 30 %% se dimensiona para **26 agentes**. Ese valor cae en el tramo de 26–50 agentes de la guía rápida oficial de Wazuh, por lo que el servidor del SIEM se dimensiona en ese tramo y no en el de 1–25.

Componente	Dimensionamiento propuesto	Justificación
Wazuh todo en uno (indexer + server + dashboard) — SRV-C23-SIEM	8 vCPU, 8 GiB de RAM, 100 GB (tramo 26–50 agentes, 90 días de alertas)	20 agentes × 1,3 = 26. Se aumenta el almacenamiento si se ingieren los logs del NGFW. En el laboratorio puede ejecutarse con recursos menores documentando la limitación.

Kaspersky Security Center — SRV-C23-KSC	Según los requisitos del fabricante para 26 dispositivos [verificar versión vigente]	Considerar base de datos, espacio para paquetes de instalación y actualizaciones.

Componente	Dimensionamiento propuesto	Justificación
GLPI en la nube — GLP-C23	2 vCPU, 4 GB de RAM, 40 GB SSD	Referencia práctica para ≤ 50 usuarios; incluir respaldos e instantánea.
Respaldos	Copia diaria de configuración (SIEM, GLPI); retención definida; prueba de restauración al menos una vez	Cubre la pérdida del servidor y errores de configuración.

5. Servicios transversales y retención

- **NTP y zona horaria:** todos los equipos sincronizan con servidores NTP públicos confiables o del proveedor cloud; zona única **America/Bogota**. Sin NTP no se pueden correlacionar alertas y tickets.
- **Nomenclatura:** PC-C23-NN, WS-C23-NN, MAC-C23-NN, UBU-C23-NN, SRV-C23-*función*, GLP-C23 (coincide con el inventario del Anexo A).
- **Retención de logs (propuesta):** 90 días en el SIEM para búsquedas rápidas y 12 meses archivados. Justificación: permite investigar incidentes tardíos de credenciales robadas y atender solicitudes de clientes dentro de contratos de confidencialidad; se ajusta si el costo de almacenamiento excede el OPEX del caso.
- **Respaldos:** configuración de Wazuh (/var/ossec/etc, reglas, decoders, tableros), exportación de GLPI y snapshot de las VM tras la configuración final.
- **Agente desconectado:** el equipo remoto puede estar apagado o sin Internet. Se define: umbral de desconexión configurable en el manager (verificar el valor por defecto de la versión instalada); un agente desconectado dentro del horario laboral genera un evento informativo; si supera el umbral definido en el Manual SOC (Fase 6) se abre ticket de severidad media y se contacta al usuario por canal alterno.

6. Responsabilidad compartida (nube y SaaS)

Servicio	Responsabilidad del proveedor	Responsabilidad de la empresa / SOC
Microsoft 365	Disponibilidad de la plataforma, seguridad física y del servicio.	Configuración de cuentas, MFA, políticas de acceso, revisión de logs de inicio de sesión (plan), respuesta a cuentas comprometidas.
Servidores en la nube (VPN, identidad)	Infraestructura física, hipervisor y red del proveedor.	Sistema operativo, parches, agentes (Wazuh, Kaspersky, GLPI Agent), reglas del NGFW, cuentas y registros.
GLPI en la nube	Infraestructura de la VM.	Endurecimiento, HTTPS, respaldos, usuarios y datos.

7. Registro de decisión de arquitectura

Decisión	Wazuh **todo en uno** (indexer, server y dashboard en SRV-C23-SIEM).
Contexto	20 equipos (26 con margen), presupuesto bajo (CAPEX ≤ COP 20 M; OPEX ≤ COP 1,5 M/mes) y un solo equipo de analistas N1.
Justificación	Para ~20 agentes la guía oficial de Wazuh respalda la instalación todo en uno. La arquitectura distribuida se justificaría por alta disponibilidad o un volumen mucho mayor (por ejemplo, ingesta de logs de M365 y del NGFW a gran escala) y exigiría al menos tres nodos, lo que incumple el tope de presupuesto.
Riesgo aceptado	Punto único de falla del SIEM: se mitiga con respaldo diario y snapshot; alta disponibilidad queda como trabajo futuro.
Revisión	Reevaluar al superar 50 agentes o si la ingesta supera la capacidad del disco asignado.

Evidencia a adjuntar (carpeta 01-arquitectura/): diagrama editable + PNG, tablas de VLAN y de flujos, hoja de dimensionamiento y este registro de decisión.